Manual de simulaciones y verificación normativa

Plataforma de monitoreo y ciberresiliencia del datacenter del Operador Postal Designado

Documento para el equipo auditor

Curso	Seguridad y Auditoría de Sistemas
Institución	Universidad Mariano Gálvez de Guatemala
Autores	Gerardo Antonio Ovando Hernández, Mario Andrés Culajay Roldán, Sergio Enrique Sánchez Sánchez
Versión	1.0, octubre de 2026
Marco normativo	ISO/IEC 27001:2022, NFPA, IEEE, ASHRAE TC 9.9 y NIST

Contenido

1. Alcance y carácter simulado 3
2. Marco normativo aplicado 3
3. Preparación para auditar 4
3.1 Cuentas necesarias 4
3.2 Estado inicial limpio 5
3.3 Cómo se registra la evidencia 5
4. Energía 5
4.1 Modelo 5
4.2 Escenarios 6
5. Ambiente 7
5.1 Modelo 7
5.2 Escenarios 8
6. Acceso físico 9
6.1 Modelo 9
6.2 Escenarios 9
7. Red 10
8. Respuesta a incidentes 10
9. Verificación de la evidencia 11
9.1 Integridad de la bitácora 11
9.2 Matriz de trazabilidad 11
9.3 Indicadores 12
10. Limitaciones conocidas 12

Este manual está dirigido al equipo que audita el proyecto. Explica cómo provocar cada escenario de energía, ambiente, acceso físico y red, qué debe registrar la plataforma, contra qué norma se evalúa y cómo comprobar la evidencia. No cubre el uso básico del tablero ni el encendido del laboratorio; para eso están `ARRANQUE.md` y `DESPLIEGUE_GNS3.md`. Cómo entrar al laboratorio en la nube: `ACCESO_AUDITORES.md`.

En la nube, la plataforma está en `https://dcim.<tailnet>.ts.net` y el punto de captura es `br-lab` en lugar de `eth2`. Los comandos `evidencia.ps1` llevan `-VM gns3@dcim`.

1. Alcance y carácter simulado

La plataforma evalúa reglas normativas sobre señales que, en el laboratorio, provienen de simuladores. El principio de diseño es **simulador = física, plataforma = norma**:

Componente	Qué es real	Qué es simulado
Red (`sensor-red`)	Captura real de tramas ARP en `eth2` de la GNS3 VM, conmutadores Open vSwitch y equipos Alpine de GNS3	La función de cada equipo (cámara, lectora, servidor) es una etiqueta del inventario
Energía (`sim-ups`)	Reglas de la plataforma y nombres de variables de Network UPS Tools	UPS, conmutador de transferencia, planta y banco de baterías
Ambiente (`sim-ambiente`)	Reglas de la plataforma, histéresis y vigilancia de sensores	Temperatura, climatización, detección de humo y supresión
Acceso físico (`sim-puerta`)	Validación de tarjeta y PIN con bcrypt, decisión de apertura	Lectora, cerradura y sensor de puerta
Autenticación y bitácora	Todo es real: WebAuthn, bcrypt, sesiones, cadena SHA-256	Nada

Los umbrales normativos viven en la plataforma (`plataforma/app/config.py`), no en los simuladores. Así, la verificación de cumplimiento recae sobre el código que tomaría las decisiones en una instalación real.

2. Marco normativo aplicado

Norma o estándar	Qué exige o aporta	Cómo se aplica en la plataforma	Módulo
ISO/IEC 27001:2022, Anexo A	Controles de seguridad de la información	Cada evento lleva su control en el campo `control_iso`; ver la matriz de la sección 9.2	Todos
NFPA 110	Sistemas de energía de emergencia y de reserva. Tipo 10: la planta debe tomar la carga en 10 s o menos. Ejercicio mensual con carga	Se mide el tiempo entre el corte y la planta en línea y se compara con 10 s. Ejercicio mensual de 30 min con carga	Energía
NFPA 111	Energía almacenada de emergencia (UPS y baterías)	Paso a batería sin interrupción, autonomía reportada frente a la de diseño, umbral de batería baja, pérdida de comunicación con el UPS	Energía

Norma o estándar	Qué exige o aporta	Cómo se aplica en la plataforma	Módulo
IEEE 1188	Mantenimiento y prueba de baterías VRLA	Umbral de batería baja al 25 % de la autonomía de diseño	Energía
ISO 22301	Continuidad del negocio	Apagado ordenado cuando se agota la autonomía	Energía
ASHRAE TC 9.9, clase A1	Temperatura de entrada de aire: recomendado de 18 a 27 °C, permisible hasta 32 °C	Clasificación con histéresis de 0.5 °C por sensor de rack; sensor sin lecturas	Ambiente
NFPA 72	Detección y alarma de incendios	Detección de humo por aspiración	Ambiente
NFPA 2001	Sistemas de extinción con agente limpio	Retardo de 30 s antes de la descarga y posibilidad de abortarla	Ambiente
NFPA 75	Protección de equipos de tecnología de la información	Referenciada en el procedimiento de alarma de humo	Ambiente
NFPA 731	Seguridad electrónica de instalaciones	Tarjeta y PIN, PIN de coacción con alerta silenciosa, puerta forzada y mantenida abierta, intentos repetidos	Acceso
IEEE 802.1X	Control de acceso a la red por puerto	Lista de permitidos por IP: todo equipo fuera del inventario es no autorizado	Red
IEEE 802.1AR	Identidad segura de dispositivos	MAC registrada por primer uso; su cambio indica sustitución	Red
IEEE 802.3bt	Alimentación por Ethernet (PoE)	Caída de un conmutador que deja sin alimentación a sus equipos, en un solo evento	Red
NIST SP 800-63B-4	Autenticación digital	Contraseña y passkey WebAuthn con verificación de usuario obligatoria, bloqueo por intentos, reautenticación	Autenticación
NIST SP 800-53, AU-9 y AC-6	Protección de registros de auditoría y mínimo privilegio	Bitácora de solo inserción con cadena de hash; roles operador, auditor y administrador	Bitácora y roles

Las variables del UPS siguen la convención de Network UPS Tools (`ups.status`, `battery.runtime`, `battery.charge`), que es una convención de la industria y no una norma.

3. Preparación para auditar

3.1 Cuentas necesarias

Rol	Para qué sirve en la auditoría
`operador`	Ejecutar las simulaciones y registrar acuses
`auditor`	Verificar la cadena de hash, exportar la bitácora y comprobar que no puede simular ni acusar

Rol	Para qué sirve en la auditoría
`administrador`	Solo lo usa el equipo del proyecto para emitir códigos de alta

Se recomienda que el equipo auditor reciba una cuenta `operador` y una `auditor`. El administrador emite los códigos en Administración; cada auditor registra su propia passkey.

3.2 Estado inicial limpio

Antes de cada escenario, en **Simulación**:

Panel	Botones, en este orden
Energía	Restablecer acometida → Reparar planta → Arranque normal, 7 s
Ambiente	Restaurar climatización → Liberar sensores → Reactivar T-RACK-B → Restablecer detección

Esperar a que Energía muestre **NORMAL** y que los dos sensores estén en rango.

3.3 Cómo se registra la evidencia

1. Antes del escenario, anotar el último `id` de la bitácora: `.\scripts\windows\evidencia.ps1 -Ultimos 1`.
2. Ejecutar el escenario.
3. Listar lo ocurrido: `.\scripts\windows\evidencia.ps1 -Desde <id>`. Con `-Csv` se guarda una copia.

Cada botón de Simulación registra primero un evento `comando_simulado` con el usuario que lo pulsó. Esto permite distinguir una prueba de un incidente real (ISO/IEC 27001 8.15).

4. Energía

4.1 Modelo

Parámetro	Valor	Fuente
Energía útil del banco de baterías	864 Wh	`ENERGIA_UTIL_WH`
Eficiencia del inversor	0.90	`EFICIENCIA_INVERSOR`
Carga protegida	566.2 W	Inventario de cargas
Autonomía de diseño	60 · 864 · 0.90 / 566.2 = **82.4 min**	Calculada
Umbral de batería baja	25 % de la autonomía = **20.6 min**	`BATERIA_BAJA_PCT`, IEEE 1188
Límite de transferencia	**10 s** (tipo 10)	`NFPA110_TIPO_S`, NFPA 110
Arranque de la planta	7 s por defecto; ajustable	Simulación
Pérdida de comunicación con el UPS	más de 10 s sin telemetría	`UPS_TIMEOUT_S`

Parámetro	Valor	Fuente
Aceleración del tiempo	La batería se descarga **x30**; el arranque de la planta corre en **segundos reales**	`FACTOR_TIEMPO`

La aceleración permite ver una descarga completa en unos 3 minutos sin perder la medición real del tiempo de transferencia, que es lo que exige NFPA 110.

Máquina de estados, visible en la pestaña Energía:

```
NORMAL → CORTE_DETECTADO → UPS_EN_BATERIA → TRANSFERENCIA_GENERADOR
                                  ↓ (falla de planta)
                              BATERIA_BAJA → APAGADO_CONTROLADO
Cualquier estado → NORMAL al volver la acometida
```

La climatización es carga de la planta, no del UPS. Sin acometida ni planta, la sala se calienta: el escenario de energía arrastra al de ambiente.

4.2 Escenarios

E1. Corte de acometida con transferencia dentro de norma

Acción	Energía → **Cortar acometida**
Se observa	Estado CORTE → UPS EN BATERÍA → TRANSFERENCIA en unos 7 s; `ups.status` pasa de OL a OB y vuelve a OL al entrar la planta
Eventos	`perdida_acometida` (crítico), `ups_en_bateria` (advertencia), `transferencia_planta` (informativo, con `transferencia_s` y `cumple: true`)
Control y norma	7.11; NFPA 110 y NFPA 111
Criterio	`transferencia_s` ≤ 10. En el ensayo del 3 de octubre: **7.47 s**
Restablecer	Restablecer acometida → evento `retorno_acometida` con la duración del incidente

E2. Transferencia fuera del tipo 10

Acción	**Arranque lento, 14 s** y luego **Cortar acometida**
Eventos	`perdida_acometida`, `ups_en_bateria`, `transferencia_fuera_de_tipo` (crítico, `cumple: false`)
Criterio	La plataforma debe marcar el incumplimiento. Ensayo: **14.47 s, NO cumple**. El indicador "Transferencias dentro del tipo 10" baja del 100 %
Restablecer	Restablecer acometida → Arranque normal, 7 s

E3. Falla de planta hasta el apagado ordenado

Acción	Con la acometida cortada: **Falla de planta**
Se observa	La carga vuelve a batería, la climatización se apaga, la autonomía cae y la sala se calienta
Eventos en orden	`falla_planta` (crítico) → `temperatura_alta` → `temperatura_critica` → `bateria_baja` (crítico) → `apagado_controlado` (crítico)

Tiempos del ensayo desde `falla_planta`	temperatura alta +13 s; crítica +27 s; batería baja +2 min 3 s; apagado +2 min 44 s
Control y norma	7.11, 7.5; NFPA 110, NFPA 111, IEEE 1188, ASHRAE TC 9.9, ISO 22301
Criterio	`bateria_baja` debe aparecer con autonomía restante ≤ 20.6 min y antes del apagado
Restablecer	Restablecer acometida → Reparar planta → Restaurar climatización. Las temperaturas vuelven al rango en menos de 1 min (`temperatura_normal`)

E4. Ejercicio mensual de la planta

Acción	**Ejercicio mensual**, con la acometida presente
Evento	`prueba_planta` a los 60 s reales (30 min simulados con carga), resultado `exitosa` si arranca en 10 s o menos
Control y norma	7.13; NFPA 110
Criterio	El indicador "Ejercicios mensuales en 12 meses" suma uno

E5. Pérdida de comunicación con el UPS. No tiene botón: se provoca deteniendo el contenedor `sim-ups` en la VM (`docker compose stop sim-ups`). A los 10 s aparece `ups_sin_comunicacion` (crítico) y al reanudarlo `ups_comunicacion_restablecida`. Control 7.11; NFPA 111. Comprueba que la plataforma no presenta un estado eléctrico desactualizado como si fuera vigente.

5. Ambiente

5.1 Modelo

Parámetro	Valor	Fuente
Sensores	T-RACK-A y T-RACK-B, temperatura de entrada de aire	ASHRAE TC 9.9
Rango recomendado, clase A1	18 a 27 °C	`TEMP_MIN_RECOMENDADA`, `TEMP_MAX_RECOMENDADA`
Máximo permisible, clase A1	32 °C	`TEMP_MAX_PERMISIBLE`
Histéresis	0.5 °C para salir de un estado	`HISTERESIS_C`
Sensor sin lecturas	más de 15 s	`SENSOR_TIMEOUT_S`
Punto de ajuste de la climatización	22 °C	Simulador
Calentamiento sin climatización	unos 0.35 °C por segundo real	Simulador
Retardo de la descarga de agente limpio	30 s	NFPA 2001

La histéresis evita que una lectura que oscila alrededor de 27 °C genere un evento por lectura. Para volver a "normal" desde advertencia, la temperatura debe bajar de 26.5 °C.

5.2 Escenarios

A1. Temperatura fuera de rango por valor fijado

Acción	**T-RACK-A a 29 °C**; luego **T-RACK-A a 34 °C**; luego **Liberar sensores**
Eventos	`temperatura_alta` (advertencia, 29 °C) → `temperatura_critica` (crítico, 34 °C) → `temperatura_normal` al liberar
Control y norma	7.5; ASHRAE TC 9.9
Criterio	Un solo evento por cambio de estado, no uno por lectura

A2. Falla de climatización

Acción	**Falla de climatización**; esperar; **Restaurar climatización**
Eventos	`temperatura_alta` en unos 15 s y `temperatura_critica` en unos 30 s, en ambos sensores; `temperatura_normal` al restaurar
Control y norma	7.5; ASHRAE TC 9.9

A3. Sensor mudo

Acción	**Silenciar T-RACK-B**; esperar 20 s; **Reactivar T-RACK-B**
Eventos	`sensor_mudo` (advertencia) a los 15 s; `sensor_restablecido` al reactivar
Control y norma	7.4, 7.5; ASHRAE TC 9.9
Criterio	Detecta la zona sin vigilancia, el caso de la cámara sin señal que nadie atendía

A4. Humo con aborto de la descarga

Acción	**Detectar humo**; antes de 30 s, **Abortar descarga**; luego **Restablecer detección**
Eventos	`alarma_humo` (crítico) → `supresion_abortada` (advertencia) → `alarma_humo_normal`
Control y norma	7.5; NFPA 72, NFPA 2001
Criterio	No debe aparecer `supresion_descargada`

A5. Humo con descarga del agente limpio

Acción	**Detectar humo** y no abortar
Eventos	`alarma_humo` → `supresion_descargada` (crítico) a los 30 s exactos
Criterio	El retardo medido entre ambos eventos es de 30 s. Ensayo: 23:18:50 → 23:19:20
Restablecer	Restablecer detección

6. Acceso físico

6.1 Modelo

Regla	Valor
Factores	Tarjeta (posesión) y PIN (conocimiento); ninguno abre por separado
PIN de coacción	El PIN real con el último dígito + 1: abre la puerta y alerta en silencio
Intentos repetidos	3 denegados con la misma tarjeta en 5 min
Puerta mantenida abierta	más de 30 s
Puerta forzada	Se abre sin una apertura autorizada en los 10 s previos
Almacenamiento de PIN	bcrypt; la plataforma nunca guarda el PIN en claro

Tarjetas de prueba:

Tarjeta	Titular	PIN	Coacción	Estado
C-1001	Técnico de turno A	1357	1358	activa
C-1002	Custodio de la sala	2468	2469	activa
C-1003	Exempleado de mantenimiento	1111	1112	revocada
C-9999	Tarjeta desconocida	cualquiera		no existe

6.2 Escenarios

#	Acción en Simulación → Puerta	Evento esperado	Control y norma
P1	C-1001 con 1357 → Presentar	`ingreso_autorizado` (informativo); la puerta abre y cierra sola a los 5 s	7.2; NFPA 731
P2	C-1001 con **1358** → Presentar	`ingreso_bajo_coaccion` (crítico). La puerta abre igual: quien está frente a la lectora no nota diferencia	7.2; NFPA 731
P3	C-1003 con 1111 → Presentar	`credencial_revocada_usada` (crítico); no abre	5.18, 7.2; NFPA 731
P4	C-1002 con 0000 tres veces	tres `ingreso_denegado` y un `intentos_repetidos` (crítico) al tercero	7.2; NFPA 731
P5	Forzar la puerta	`puerta_forzada` (crítico)	7.2, 7.4; NFPA 731
P6	C-1002 con 2468 → Entrar y dejar abierta	`ingreso_autorizado` y, a los 30 s, `puerta_mantenida_abierta` (advertencia)	7.2, 7.4; NFPA 731
P7	C-9999 con cualquier PIN	`ingreso_denegado` por tarjeta desconocida	7.2

Punto de auditoría para P2: el evento se registra como crítico y aparece en las alertas del tablero, pero la respuesta enviada a la lectora es la misma que en un ingreso válido.

7. Red

La red no se simula con botones: los escenarios se provocan en GNS3 y la plataforma los detecta en el tráfico real de `eth2`.

Parámetro	Valor
Equipo caído	sin tráfico durante 8 s (`UMBRAL_DESCONEXION_S`), revisado cada 3 s
Capturador detenido	más de 10 s sin observaciones
Límite de avisos de no autorizados	10 por minuto, después un evento `inundacion_red`

#	Acción en GNS3	Evento esperado	Control y norma
R1	Encender **PC-INTRUSO** (10.10.10.66, fuera del inventario)	`dispositivo_no_autorizado` (crítico)	8.20; IEEE 802.1X
R2	Consola de CAM-02: `ip link set eth0 down; ip link set eth0 address 02:42:de:ad:be:ef; ip link set eth0 up`	`suplantacion` (crítico): la MAC observada no es la registrada	7.2; IEEE 802.1AR
R3	Detener **SW-CIRC-B**	un solo `cascada_poe` (crítico) con LECT-01, CAM-03 y PC-NAVE	7.8, 7.11; IEEE 802.3bt
R4	Detener **SW-CIRC-A**	`perdida_visibilidad` (crítico), no una caída por equipo	8.16
R5	Detener un solo Alpine, por ejemplo CAM-01	`dispositivo_desconectado`	7.8

Para restablecer R2: `ip link set eth0 down; ip link set eth0 address 02:42:70:ba:6a:00; ip link set eth0 up`.

Punto de auditoría para R3 y R4: la plataforma distingue la caída de un conmutador, la de un equipo y la del propio punto de captura. Esto evita cinco alertas sueltas cuando la causa es una sola.

8. Respuesta a incidentes

Cada evento crítico queda pendiente de acuse. **Resumen → Atender** muestra el procedimiento de respuesta del tipo de evento (`plataforma/app/procedimientos.py`) y permite registrar un acuse con nota. El acuse es un evento nuevo `acuse` cuyo `ref_id` apunta al evento atendido; el original no se modifica.

Verificación	Cómo
Hay procedimiento para cada tipo crítico	Abrir Atender en alertas de distintos módulos
El auditor no puede acusar	Con la cuenta `auditor`, la ventana indica que el rol no registra acuses
Tiempo de acuse	Indicador "Tiempo medio de acuse", meta ≤ 5 min

9. Verificación de la evidencia

9.1 Integridad de la bitácora

Cada evento guarda `hash = SHA-256(hash_anterior ‖ JSON canónico del evento)`. Modificar, borrar o insertar una fila rompe la cadena desde ese punto.

Prueba	Cómo	Resultado esperado
Verificación en el tablero	Bitácora → Verificar cadena (cuenta auditor)	"Íntegra: N eventos encadenados" y evento `verificacion_cadena`
Verificación desde fuera	`.\scripts\windows\evidencia.ps1`	"Cadena de hash ÍNTEGRA"
Exportación	Bitácora → Exportar CSV	Archivo con `hash_anterior` y `hash` por fila; evento `exportacion`
Solo inserción	Revisar `plataforma/app/bitacora.py`	Solo hay `INSERT` sobre `eventos`; no existen `UPDATE` ni `DELETE`

9.2 Matriz de trazabilidad

Control ISO/IEC 27001:2022	Norma técnica	Escenarios	Eventos
5.18 Derechos de acceso	NFPA 731	P3	`credencial_revocada_usada`
5.26 Respuesta a incidentes		Sección 8	`acuse`
7.2 Entrada física	NFPA 731; IEEE 802.1AR	P1 a P7, R2	`ingreso_*`, `intentos_repetidos`, `puerta_*`, `suplantacion`
7.4 Monitoreo de la seguridad física	NFPA 731; ASHRAE TC 9.9	P5, P6, A3	`puerta_forzada`, `puerta_mantenida_abierta`, `sensor_mudo`
7.5 Amenazas físicas y ambientales	ASHRAE TC 9.9; NFPA 72; NFPA 2001	A1 a A5, E3	`temperatura_*`, `alarma_humo`, `supresion_*`
7.8 Emplazamiento de equipos	IEEE 802.3bt	R3, R5	`cascada_poe`, `dispositivo_desconectado`
7.11 Servicios de suministro	NFPA 110; NFPA 111; IEEE 1188	E1 a E3, E5	`perdida_acometida`, `transferencia_*`, `bateria_baja`, `apagado_controlado`, `ups_sin_comunicacion`
7.13 Mantenimiento de equipos	NFPA 110	E4	`prueba_planta`
8.5 Autenticación segura	NIST SP 800-63B-4	Ingreso, reautenticación	`auth_exitosa`, `auth_fallida`, `auth_bloqueo`, `reautenticacion`

Control ISO/IEC 27001:2022	Norma técnica	Escenarios	Eventos
8.15 Registro	NIST SP 800-53 AU-9	Sección 9.1	`verificacion_cadena`, `exportacion`, `comando_simulado`
8.16 Actividades de monitoreo		R4	`perdida_visibilidad`, `capturador_caido`
8.20 Seguridad de redes	IEEE 802.1X	R1	`dispositivo_no_autorizado`, `inundacion_red`

9.3 Indicadores

La pestaña Indicadores calcula sobre la bitácora los nueve indicadores de verificación del Entregable 2: detección de desconexión (≤ 11 s), acuse (≤ 5 min), transferencias dentro del tipo 10 (100 %), autonomía reportada frente a diseño (≥ 90 %), ejercicios de planta (12 de 12), minutos sobre 27 °C, cuentas con passkey (100 %), revocación en bajas (100 %) e integridad de la bitácora (100 %).

10. Limitaciones conocidas

Limitación	Efecto en la auditoría
Energía, ambiente y acceso son simulados	Se verifica la lógica normativa de la plataforma, no equipos físicos
La descarga de la batería está acelerada x30	Las duraciones de autonomía son simuladas; el tiempo de transferencia es real
MQTT sin TLS dentro de la red interna de Docker	En producción se activaría TLS y OSDP con canal seguro para las lectoras
802.1X por lista de permitidos IP y MAC, no por autenticación de puerto con FreeRADIUS	Se detecta el equipo no autorizado, pero no se le bloquea el puerto
La GNS3 VM local tiene 1 CPU	Al encender nodos, la VM se satura y aparecen eventos falsos de `capturador_caido`, `sensor_mudo`, `ups_sin_comunicacion` y `cascada_poe` durante 2 o 3 min. Los eventos del ensayo afectados están identificados en `REGISTRO_VALIDACION.md` (hallazgo H1). La VM de Azure tiene 4 CPU para evitarlo
Los comandos de ensayo enviados directamente al broker no registran `comando_simulado`	Solo los botones de Simulación dejan el actor; el ensayo del 3 de octubre usó el broker para los pasos 5 a 10